

CYBERSECURITY

GHI CHÚ ĐẦY ĐỦ

(Cybersecurity)



Network
Security



Ethical
Hacking



Firewalls &
Defense



Malware
Analysis



Threat
Protection

BEGINNER TO ADVANCED

01. NỀN TẢNG CYBERSECURITY

1

1 Cybersecurity là gì?

Cybersecurity là hoạt động bảo vệ hệ thống, mạng, ứng dụng và dữ liệu khỏi truy cập trái phép, tấn công, hư hại hoặc gián đoạn. Nó đảm bảo tính bảo mật (confidentiality), toàn vẹn (integrity) và sẵn sàng (availability) của thông tin và hệ thống.

3 Vì sao Security quan trọng?

- Bảo vệ **dữ liệu nhạy cảm** và quyền riêng tư người dùng
- Ngăn ngừa **tổn thất tài chính** và gian lận
- Đảm bảo **tính liên tục kinh doanh** và sự tin tưởng
- Giúp đáp ứng các yêu cầu pháp lý, quy định và **compliance**
- Bảo vệ **uy tín** và giá trị thương hiệu

2 Cybersecurity vs Information Security

Khía cạnh	Cybersecurity	Information Security
Trọng tâm	Bảo vệ hệ thống, mạng và tài sản số	Bảo vệ mọi loại thông tin
Phạm vi	Technology, networks, applications, devices	Con người, quy trình và công nghệ
Nguy cơ	Hacker, malware, DDoS, phishing, exploits	Lạm dụng nội bộ, rò rỉ, đe dọa vật lý
Mục tiêu	Ngăn chặn tấn công mạng và xâm phạm hệ thống	Bảo vệ thông tin dưới mọi hình thức

4 Hệ sinh thái Cybersecurity

Devices

Endpoints
Servers
Mobile Devices
IoT Devices

Applications

Web Apps
Mobile Apps
APIs
SaaS Apps

People

Users
Admins
Employees
Third Parties

Networks

LAN / WAN
Wi-Fi
VPN
Internet

Data

Databases
Files
Backups
Cloud Storage

**Bảo vệ
People, Data
và Systems**

Threats

Malware
Phishing
Exploits
Insider Threats
DDoS

Security Controls

Prevent
Detect
Respond
Recover

Threat Landscape

Nation-State Actors

Advanced persistent threats, espionage, cyber warfare.

Cyber Criminals

Financial gain, ransomware, data theft.

Hacktivists

Ideological motives, website defacement, DDoS.

Insiders

Malicious or negligent employees.

Script Kiddies

Low skill attackers using readymade tools.

6 Attack Surface

Tổng số điểm mà một unauthorized user có thể cố gắng xâm nhập hoặc lấy dữ liệu.

Bao gồm:

- Open ports, services, APIs
- Web applications
- User accounts & permissions
- Devices, endpoints, cloud resources
- Third-party integrations

7 Basic Security Controls

🛡️ **Prevent** — Firewalls, access control, encryption, patching

🔍 **Detect** — IDS/IPS, monitoring, logs, threat intelligence

🚨 **Respond** — Kế hoạch incident response, alerts, containment

🔄 **Recover** — Backups, disaster recovery, business continuity

Remember

Security không phải là một sản phẩm, mà là một quy trình.
People + Process + Technology = Strong Security

Common Mistake

Nghĩ rằng security chỉ là việc của đội IT.
Thực tế: Mọi người đều có trách nhiệm với security.

Interview Tip

Giải thích rõ CIA Triad, các loại Threat, Attack surface và Security controls kèm ví dụ cụ thể.

02. CIA TRIAD & CÁC NGUYÊN TẮC SECURITY

2

1 CIA Triad là gì?

CIA Triad là nền tảng của Information Security.

Nó đảm bảo hệ thống và dữ liệu luôn **Confidential, Integrity** và **Available** đối với người dùng được ủy quyền.

Confidentiality đảm bảo dữ liệu chỉ có thể truy cập bởi người dùng được ủy quyền.

Integrity đảm bảo dữ liệu chính xác, đầy đủ và không bị thay đổi trái phép.

Availability đảm bảo hệ thống và dữ liệu luôn sẵn sàng khi người dùng được ủy quyền cần dùng.



2 Security Principles

- Authentication** Xác minh danh tính của người dùng hoặc hệ thống.
- Authorization** Xác định những gì một authenticated user được phép truy cập.
- Non-repudiation** Đảm bảo các hành động có thể truy vết và không thể bị chối bỏ sau này.
- Least Privilege** Người dùng và hệ thống chỉ có quyền truy cập tối thiểu cần thiết để thực hiện công việc.

3 Chúng phối hợp với nhau ra sao?

Security không chỉ là một control, mà là sự kết hợp của mọi nguyên tắc để cùng bảo vệ **dữ liệu, hệ thống và người dùng**.



Important Note

Không hệ thống nào an toàn 100%, nhưng tuân theo các nguyên tắc này giúp giảm đáng kể risk và impact của các cuộc tấn công.

4 Vì sao các nguyên tắc này quan trọng?

- Bảo vệ dữ liệu nhạy cảm khỏi truy cập trái phép hoặc rò rỉ.
- Ngăn chặn giả mạo dữ liệu và duy trì sự tin tưởng.
- Đảm bảo tính liên tục kinh doanh và uptime.
- Giúp đáp ứng yêu cầu compliance và pháp lý.
- Xây dựng lòng tin người dùng và uy tín tổ chức.

Remember

CIA Triad bảo vệ CÁI GÌ, Security Principles bảo vệ NHƯ THẾ NÀO.

Common Mistake

Cấp nhiều quyền hơn mức cần thiết hoặc không áp dụng least privilege.

Interview Tip

Luôn liên hệ CIA Triad và Security Principles trong câu trả lời của bạn kèm ví dụ.

03. NỀN TẢNG NETWORKING CHO SECURITY

3

1 Khái niệm chính

- IP Address (Logical Address):** Định danh một thiết bị trên mạng.
 - IPv4 (32-bit) v.d. 192.168.1.10, IPv6 (128-bit)
- MAC Address (Physical Address):** Địa chỉ phần cứng duy nhất gắn với network interface.
 - v.d. 00:1A:2B:3C:4D:5E
- Ports:** Điểm cuối logic dùng bởi các protocol để định danh applications/services. Range: 0 – 65535
- DNS (Domain Name System):** Chuyển đổi domain name (google.com) thành IP address.
- HTTP vs HTTPS:** HTTP không mã hóa (Port 80). HTTPS được mã hóa bằng TLS/SSL (Port 443).

2 Các Port phổ biến

Port	Service
21	FTP
22	SSH
23	Telnet (Insecure)
53	DNS
80	HTTP
443	HTTPS
3306	MySQL
3389	RDP

2 Network Flow (High Level)



Ví dụ kết nối

Client gửi request đến https://example.com (Port 443)

- DNS resolve domain
- TCP connection được thiết lập
- TLS handshake (HTTPS)
- Trao đổi dữ liệu an toàn

3 TCP vs UDP

Feature	TCP	UDP
Connection	Connection-Oriented	Connectionless
Reliability	Reliable (ACK, Retransmission)	Unreliable
Speed	Chậm hơn	Nhanh hơn
Use Cases	Web, Email, File Transfer, SSH, HTTPS	DNS, VoIP, Streaming, Gaming
Header Size	20 – 60 bytes	8 bytes

4 Các tầng TCP/IP (4 Layers)

4	Application Layer (HTTP, DNS, SMTP)	Cung cấp network services cho user applications
3	Transport Layer (TCP, UDP)	Giao tiếp end-to-end, ports, segmentation
2	Internet Layer (IP, ICMP)	Đánh địa chỉ logic và routing (IP)
1	Network Access Layer (Ethernet, Wi-Fi)	Giao tiếp vật lý (MAC addressing)

★ Vì sao Networking quan trọng

- ✓ Giúp hiểu cách attack di chuyển qua các mạng.
- ✓ Cần thiết cho firewall rules, IDS/IPS và segmentation.
- ✓ Hỗ trợ troubleshoot các vấn đề security.
- ✓ Cần thiết cho penetration testing và incident response.
- ✓ Giúp cấu hình an toàn cho applications và services.

★ Remember

IP = Nơi thiết bị ở
MAC = Thiết bị là ai
Ports = Dịch vụ nào
TCP = Reliable
UDP = Fast

⚠ Common Mistake

Mở các port không cần thiết trên firewall khiến hệ thống bị lộ trước tấn công.

✓ Interview Tip

Nắm rõ các well-known ports, khác biệt TCP vs UDP và vai trò của DNS, HTTP & HTTPS.

💡 Ví dụ dễ hiểu

Network giống một thành phố:
IP = Địa chỉ
Ports = Phòng ban
Protocols = Quy tắc giao tiếp

04. THREATS, VULNERABILITIES & RISKS

4

1 Thuật ngữ chính

- **Threat:** Bất cứ điều gì có khả năng gây hại cho hệ thống, dữ liệu hoặc người dùng.
- **Vulnerability:** Một điểm yếu hoặc lỗ hổng có thể bị threat khai thác.
- **Exploit:** Kỹ thuật hoặc code lợi dụng một vulnerability.
- **Impact:** Thiệt hại hoặc ảnh hưởng đến confidentiality, integrity hoặc availability.
- **Risk:** Khả năng một threat sẽ khai thác vulnerability và gây ra impact.
- **Threat Actor:** Cá nhân, nhóm hoặc tổ chức khởi xướng threats.

2 Attack Concepts



3 The Risk Chain

Cải thiện controls để phá vỡ chuỗi này ◀



4 Threat Actors

- **Cyber Criminals:** Tìm lợi ích tài chính qua trộm cắp, gian lận, ransomware, v.v.
- **Hacktivists:** Bị thúc đẩy bởi ý thức hệ hoặc mục đích chính trị.
- **Nation-State Actors:** Thực hiện gián điệp, phá hoại hoặc cyber warfare.
- **Insider Threats:** Nhân viên hoặc trusted users lạm dụng quyền truy cập (có ý hoặc vô ý).
- **Script Kiddies:** Attacker thiếu kinh nghiệm dùng công cụ và exploit có sẵn.

5 Risk Formula

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

- Threat Capability
- Vulnerability Likelihood
- Exposure (Attack Surface)
- Confidentiality Loss
- Integrity Damage
- Availability Downtime
- Financial / Legal Impact
- Reputation Damage

Important Note

Security là việc giảm Risk bằng cách giảm Vulnerabilities, giới hạn Attack Surface và tăng cường Controls.

Remember

Bạn không thể loại bỏ Risk hoàn toàn. Bạn chỉ có thể giảm nó. Tập trung vào những gì quan trọng nhất.

Interview Tip

Luôn nghĩ: Điều gì có thể sai? Điểm yếu ở đâu? Impact là gì? Khả năng xảy ra ra sao?

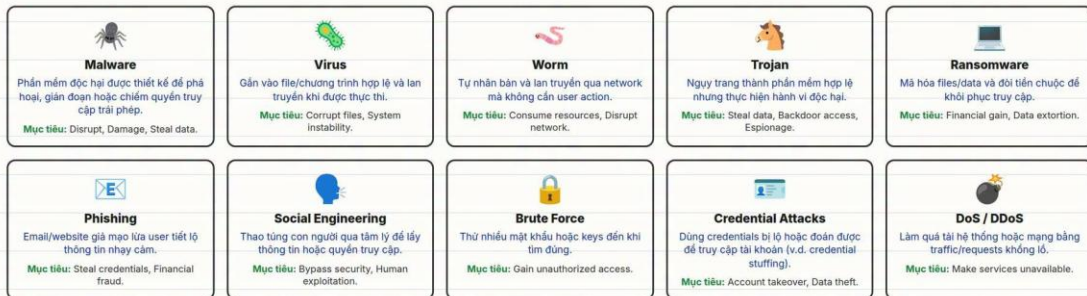
05. CÁC CYBER ATTACK PHỔ BIẾN

5

1 Cyber Attacks là gì?

Cyber attacks là những nỗ lực có ác ý nhằm truy cập, đánh cắp, thay đổi, vô hiệu hóa hoặc phá hủy hệ thống, mạng hoặc dữ liệu.

2 Attack Taxonomy (High Level)



★ Important Note

Attacker có thể kết hợp nhiều loại attack trong một chiến dịch.
Ví dụ: Phishing email → Malware delivery → Ransomware execution

✓ Best Practice

- ✓ Luôn cập nhật hệ thống & apps
- ✓ Dùng mật khẩu mạnh & MFA
- ✓ Đào tạo nhận thức người dùng
- ✓ Backup dữ liệu định kỳ
- ✓ Triển khai defense in depth

★ Remember

Identify → Detect → Prevent → Respond → Recover
(Security Lifecycle)

⚠ Common Mistake

Người dùng click vào link hoặc tải attachment từ nguồn không đáng tin.

✓ Interview Tip

Nắm rõ mục đích, impact và cách phòng ngừa cho từng loại attack kèm ví dụ thực tế.

06. NỀN TẢNG CRYPTOGRAPHY

6

1 Khái niệm cốt lõi

- Encryption:** Chuyển đổi dữ liệu đọc được (Plaintext) thành dữ liệu không đọc được (Ciphertext) bằng một key.
- Encoding:** Chuyển đổi dữ liệu từ format này sang format khác (v.d. Base64) – KHÔNG phải để bảo mật.
- Hashing:** Chuyển đổi dữ liệu thành output có độ dài cố định (Hash). Quá trình một chiều, không thể đảo ngược.

2 Luồng cơ bản



3 Các loại Cryptography

(A) Symmetric Encryption (Shared Key)

- Cùng một secret key được dùng để encrypt và decrypt.
- Nhanh hơn, phù hợp cho dữ liệu lớn.

Plaintext → Encrypt → Ciphertext → Decrypt → Plaintext
(dùng chung Shared Secret Key)

(B) Asymmetric Encryption (Public Key)

- Dùng một cặp keys: Public Key và Private Key.
- Public key encrypt, Private key decrypt.
- Chậm hơn, dùng cho trao đổi key an toàn & digital signatures.

Plaintext → Encrypt(Public Key) → Ciphertext → Decrypt(Private Key) → Plaintext

4 Hash Functions

- Hàm một chiều. Dữ liệu gốc không thể phục hồi.
- Chỉ một thay đổi nhỏ trong input cũng tạo ra hash hoàn toàn khác.

Input	Hash (SHA-256)
Hello	185F80B32271FE25...
hello	B6FC4C620B67D95F...
Hello!	7F355E862A9B1FFB...

5 Digital Signatures

- Đảm bảo authenticity, integrity và non-repudiation.
- Signer dùng private key để ký.
- Bất kỳ ai cũng có thể verify bằng public key.

Data → Sign(Private Key) → Signature → Verify(Public Key)

6 PKI Basics

- Public Key Infrastructure (PKI) quản lý keys và digital certificates.
- Dùng Certificate Authorities (CA) để xác thực danh tính.

User → CSR → CA → Certificate → Trusted ✓

★ Remember

Encryption = Security
Encoding = Format
Hashing = Integrity

⚠ Important Note

Không hardcode keys. Dùng thuật toán mạnh như AES, RSA, SHA-256.

✓ Best Practice

- ✓ Dùng TLS/SSL cho data in transit
- ✓ Mã hóa dữ liệu nhạy cảm at rest
- ✓ Bảo vệ private keys cẩn thận
- ✓ Xoay vòng keys định kỳ

💡 Interview Tip

Nắm rõ khác biệt Symmetric vs Asymmetric, Hashing, Digital Signatures và PKI.

07. AUTHENTICATION & ACCESS CONTROL

7

1 Khái niệm chính

- **Authentication:** Xác minh danh tính của user hoặc hệ thống. (Bạn là ai?)
- **Authorization:** Xác định những gì một authenticated user được phép làm. (Bạn được truy cập gì?)
- **Access Control:** Chính sách và cơ chế thực thi các quyết định authorization.
- **Mục tiêu:** Đảm bảo đúng người đúng có đúng quyền truy cập, vào đúng thời điểm, vì đúng lý do.

2 Các phương thức Authentication

- **Something you know** Password, PIN, Security questions
- **Something you have** OTP, Mobile, Smart card, Hardware token
- **Something you are** Biometrics: Fingerprint, Face, Iris

★ **MFA (Multi-Factor Authentication)**
Kết hợp hai hoặc nhiều yếu tố để xác minh danh tính. Giảm đáng kể nguy cơ tài khoản bị chiếm quyền.

3 Access Control Models

RBAC (Role-Based Access Control)	ABAC (Attribute-Based Access Control)	DAC (Discretionary Access Control)	MAC (Mandatory Access Control)
 Quyền truy cập cấp theo user roles. Ví dụ: Admin, User, Auditor	 Truy cập cấp theo attributes và policies. Ví dụ: Chỉ cho phép truy cập từ mạng văn phòng trong giờ làm việc.	 Chủ sở hữu resource quyết định ai được truy cập. Ví dụ: Chủ file cấp quyền cho người khác.	 Top Secret / Secret / Confidential / Public Truy cập dựa trên security labels/clearance. Dùng trong hệ thống chính phủ, quân sự.

4 Access Flow (High Level)



08. NETWORK SECURITY

8

1 Khái niệm chính

- **Firewall:** Kiểm soát traffic ra/vào mạng.
- **IDS:** Giám sát traffic để phát hiện hoạt động khả nghi và tạo alert.
- **IPS:** Chủ động chặn hoặc ngăn traffic độc hại.
- **VPN:** Tạo encrypted tunnel qua mạng không tin cậy.
- **Proxy:** Đóng vai trò trung gian giữa clients và servers.
- **NAC:** Đảm bảo chỉ thiết bị đáng tin cậy & tuân thủ mới truy cập mạng.
- **Network Segmentation:** Chia mạng thành các zone nhỏ để giới hạn di chuyển.
- **Defense in Depth:** Nhiều lớp security controls để giảm risk.

2 Kiến trúc Network Security nhiều lớp

7 Data/Application Layer WAF, App Security, Secure Coding, DNS Security	Bảo vệ data & applications khỏi tấn công.
6 Monitoring & Response SIEM, Log Analysis, SOC, Threat Intel	Phát hiện, cảnh báo và phản ứng với threats.
5 Access Control Layer NAC, IAM, MFA, Zero Trust	Đảm bảo chỉ user/device được ủy quyền truy cập.
4 Network Security Layer IDS/IPS, VPN, Proxy, Email Security	Giám sát và lọc traffic độc hại.
3 Perimeter Security Layer Firewalls, DMZ, Anti-DDoS, Rate Limiting	Chặn truy cập trái phép tại perimeter.
2 Network Segmentation Layer VLANs, Subnets, Internal Firewalls	Giới hạn di chuyển ngang trong mạng.
1 Physical Layer Physical Security, Cabling, Power	Bảo vệ hạ tầng vật lý.

3 Các thành phần Security giải thích

Firewall • Lọc traffic theo rules (IP, Port, Protocol) • Stateful/Next-Gen Firewalls kiểm tra sâu • Loại: Packet Filter, Stateful, NGFW	IDS • Giám sát traffic/logs • Phát hiện pattern khả nghi • Passive – chỉ cảnh báo • Loại: NIDS, HIDS	IPS • Chủ động chặn threats • Kiểm tra inline traffic • Ngăn tấn công real-time • Loại: NIPS, HIPS	VPN • Tạo encrypted tunnel • Đảm bảo confidentiality • Loại: Remote Access, Site-to-Site	Proxy Server • Trung gian client & server • An internal network • Dùng cho caching, filtering	NAC • Kiểm tra device posture • Thực thi compliance trước khi truy cập • Ví dụ: 802.1X, Cisco ISE
--	---	---	---	--	--

4 Network Segmentation

- Chia mạng thành các zone nhỏ hơn.
- Hạn chế giao tiếp giữa các segment.
- Ngăn di chuyển ngang bởi attacker.

VLAN 10
Finance

VLAN 20
HR

VLAN 30
IT

★ Remember

Firewall = Kiểm soát truy cập
IDS = Phát hiện
IPS = Ngăn chặn
VPN = Secure Tunnel
NAC = Trust but Verify

⚠ Common Mistake

Chỉ dựa vào Firewall. Mạng phẳng không segmentation. Bỏ qua internal threats.

5 Defense in Depth

Physical Security (Locks, CCTV, Guards) → **Perimeter Security** (Firewalls, DDoS Protection) → **Network Security** (IDS/IPS, VPN, Proxy) → **Access Control** (NAC, IAM, MFA) → **Endpoint Security** (EDR, Antivirus, Patching) → **Application Security** (WAF, Secure Code) → **Data Security** (Encryption, DLP, Backups)

Nhiều lớp đảm bảo nếu một lớp thất bại, các lớp khác vẫn bảo vệ hệ thống.

✅ Best Practice

- ✓ Dùng layered security
- ✓ Bật logging & monitoring
- ✓ Segment mạng đúng cách
- ✓ Cập nhật patch cho thiết bị

💡 Interview Tip

Giải thích rõ cách mỗi control hoạt động và phối hợp (Defense in Depth). Vẽ kiến trúc phân lớp nếu có thể.

09. WEB APPLICATION SECURITY

9

1 Web Application Security là gì?

Web Application Security bảo vệ websites và web APIs khỏi các tấn công khai thác vulnerabilities trong code, thiết kế, logic hoặc configuration.

Mục tiêu: Bảo vệ dữ liệu, duy trì integrity, đảm bảo availability và giữ vững sự tin tưởng.

2 OWASP Top 10 (2021)

1. Broken Access Control
2. Cryptographic Failures
3. Injection
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable & Outdated Components
7. Identification & Authentication Failures
8. Software & Data Integrity Failures
9. Security Logging & Monitoring Failures
10. Server-Side Request Forgery (SSRF)

3 Web Request → Application → Database (Luồng Attack/Defense)



Attack Path (Ví dụ)



4 Các Web Attack phổ biến



10. CLOUD SECURITY

10

1 Nền tảng Cloud Security

- Cloud Security là hoạt động bảo vệ dữ liệu, applications, workloads và infrastructure trong cloud environments.
- Bao gồm con người, quy trình, công nghệ và chính sách.
- Mục tiêu: Confidentiality, Integrity, Availability và Compliance trong cloud.

2 Shared Responsibility Model

On-Premises (Bạn quản lý mọi thứ)	IaaS (Shared)	SaaS (Provider quản lý nhiều hơn)
Data	Data	Data
Applications	Applications	Applications
Runtime	Runtime	Runtime
OS	OS	OS
Servers	Servers	Servers
Networking	Networking	Networking

Quyền kiểm soát càng nhiều = Trách nhiệm càng lớn. Tiềm lợi càng nhiều = Càng tin tưởng provider.

3 Cloud IAM (Identity & Access Management)



- Identity, roles và permissions tập trung.
- Dùng RBAC / ABAC, Least Privilege và MFA.
- Giám sát và audit quyền truy cập định kỳ.

4 Storage Security

- Mã hóa data at rest (Server-side encryption)
- Dùng secure buckets & policies
- Kiểm soát public access
- Versioning + Backup
- Bật logging

5 Secrets Management

- Lưu secrets trong vaults (AWS Secrets Manager, Azure Key Vault...)
- Xoay vòng secrets định kỳ
- Không bao giờ hardcode secrets

6 Misconfiguration Risks

- Open storage buckets
- IAM policies quá lỏng lẻo
- Databases công khai
- Dữ liệu chưa mã hóa
- Default accounts

7 Container Security Basics

- Scan container images tìm vulnerabilities
- Dùng minimal base images
- Chạy containers non-root
- Bảo mật Kubernetes

8 Kiến trúc Cloud Security (High Level)



Security Controls: Encryption, Least Privilege, Network Security, Monitoring, Patching, Compliance

Remember

Cloud chuyển giao trách nhiệm, không loại bỏ nó.
Security là một hành trình chung.

Common Mistake

Cho rằng cloud provider bảo mật mọi thứ. Bỏ qua việc kiểm tra cấu hình.

Best Practice

- ✓ Tuân theo Least Privilege
- ✓ Bật Logging & Monitoring
- ✓ Mã hóa mọi thứ
- ✓ Audit và review định kỳ

Interview Tip

Sẵn sàng giải thích Shared Responsibility Model và ví dụ thực tế về misconfiguration.

11. ENDPOINT & SYSTEM SECURITY

11

1 Khái niệm chính

- Endpoint Security bảo vệ các thiết bị như laptops, desktops, servers, mobile phones và IoT devices.
- Mục tiêu: Ngăn ngừa, phát hiện và phản ứng với threats nhắm vào endpoints.
- Endpoint security mạnh giúp giảm nguy cơ malware, đánh cắp dữ liệu và truy cập trái phép.

2 Các lớp phòng thủ Endpoint (Defense in Depth)



3 Các thành phần chính giải thích

1. OS Hardening Bảo mật OS bằng cách tắt các service không dùng, đổi cấu hình mặc định, thực thi chính sách mạnh. Ví: Disable Guest, Mật khẩu mạnh, Bật Firewall	2. Secure Config Áp dụng security baselines và tiêu chuẩn cấu hình. Ví: CIS Benchmarks, Group Policy	3. Patch Mgmt Cập nhật OS và phần mềm định kỳ để vá các vulnerabilities đã biết. Ví: Windows Update, WSUS	4. Antivirus Phát hiện và chặn malware, ransomware, trojan và các file độc hại khác. Ví: Windows Defender, Kaspersky	5. EDR Giám sát hành vi endpoint, phát hiện threats và hỗ trợ incident response. Ví: CrowdStrike, SentinelOne	6. App Control Chỉ cho phép các apps tin cậy chạy, chặn apps không xác định hoặc độc hại. Ví: AppLocker, WDAC	7. Device Security Bảo vệ tránh bị khôi phục dữ liệu sau khi bị đánh cắp hoặc truy cập trái phép. Ví: BitLocker, Remote Wipe
---	---	--	---	--	--	---

✓ Best Practices

- ✓ Cập nhật OS, apps, drivers thường xuyên
- ✓ Dùng mật khẩu mạnh và MFA
- ✓ Bật firewall & endpoint protection
- ✓ Áp dụng least privilege cho user
- ✓ Giám sát logs & alerts liên tục
- ✓ Backup dữ liệu quan trọng định kỳ

⚠ Common Mistakes

- Bỏ qua system updates
- Dùng cấu hình mặc định
- Luôn chạy với quyền administrator
- Tải phần mềm không tin cậy
- Không backup hoặc logging

★ Remember

Endpoint mạnh = Security posture mạnh. Bảo vệ endpoint bảo vệ dữ liệu, người dùng và doanh nghiệp.

🎯 Key Takeaway

Layered security trên endpoint đảm bảo prevention, detection và response.

12. EMAIL & SOCIAL ENGINEERING SECURITY

12

1 Các loại tấn công qua Email

- Phishing:** Email lừa đảo hàng loạt gửi đến nhiều user để đánh cắp credentials hoặc phát tán malware.
- Spear Phishing:** Tấn công nhắm mục tiêu vào một cá nhân cụ thể bằng thông tin cá nhân hóa.
- Whaling:** Nhắm vào các executives cấp cao (CEO, CFO) để lừa họ thực hiện hành động nhạy cảm.
- Business Email Compromise (BEC):** Attacker giả mạo liên hệ tin cậy để đánh cắp tiền hoặc dữ liệu.

2 Các bẫy thường gặp trong Email

- Malicious Attachments:** File chứa malware (exe, docm, zip, js, v.v.)
- Malicious Links:** Link dẫn đến website giả để đánh cắp credentials hoặc cài malware.
- Social Engineering Psychology:** Attacker khai thác cảm xúc con người – sợ hãi, cấp bách, tò mò, tham lam hoặc lòng tin để thao túng hành động.

3 Giải phẫu một Phishing Email

Hộp thư đến

From: support@secure-login.com
To: victim@company.com
Subject: Khẩn: Xác minh tài khoản ngay!

Kính gửi Quý khách,
Chúng tôi phát hiện hoạt động bất thường trên tài khoản của bạn. Tài khoản sẽ bị khóa trong 24 giờ nếu bạn không xác minh ngay.
Vui lòng nhấn nút bên dưới để xác minh tài khoản.

XÁC MINH TÀI KHOẢN Hover: <http://malicious-login.com>

Trân trọng,
Đội hỗ trợ tài khoản

- **Dấu hiệu cảnh báo**
- Domain lạ hoặc giả mạo trong địa chỉ sender
- Lời chào chung chung ("Kính gửi Quý khách")
- Ngôn từ khẩn cấp / đe dọa
- Link khả nghi (hover để kiểm tra URL)
- Attachment bất ngờ
- Lỗi ngữ pháp & chính tả
- Yêu cầu thông tin nhạy cảm (password, OTP, thẻ)

4 Phòng ngừa & Best Practices

- ✓ Kiểm tra kỹ địa chỉ email người gửi.
- ✓ Hover qua link trước khi click. Kiểm tra URL thật.
- ✓ Không mở attachment không mong đợi.
- ✓ Không bao giờ chia sẻ password, OTP, PIN hoặc thông tin nhạy cảm.
- ✓ Báo cáo email khả nghi cho đội IT/Security.
- ✓ Bật MFA cho mọi tài khoản.
- ✓ Duy trì nhận thức security và cập nhật kiến thức thường xuyên.
- ✓ Dùng email filtering, anti-phishing và sandboxing.

Remember

Attacker không phá hệ thống, họ lừa con người.
Luôn cảnh giác. Suy nghĩ trước khi click!

5 Các kỹ thuật Social Engineering

Attacker → **Pretexting** (tạo câu chuyện) · **Baiting** (mồi nhử) · **Quid Pro Quo** (đổi trao giúp đỡ/thông tin) · **Tailgating** (bám theo vào khu vực an toàn) · **Impersonation** (giả danh người đáng tin) → Victim

Best Practice

- ✓ Xác minh trước khi tin tưởng
- ✓ Dùng MFA mọi nơi
- ✓ Cập nhật hệ thống & công cụ
- ✓ Đào tạo user thường xuyên

Common Mistake

- Click mà không suy nghĩ
- Bỏ qua các dấu hiệu nhỏ
- Chia sẻ quá nhiều thông tin
- Cho rằng email là thật

Key Takeaway

Email có thể là attack vector rất mạnh.
Awareness + Verification = Phòng thủ tốt nhất.

Interview Tip

Sẵn sàng giải thích các loại phishing, red flags và cách xử lý một phishing incident thực tế.

13. VULNERABILITY MANAGEMENT

13

1 Vulnerability Management là gì?

Vulnerability Management là quá trình liên tục identify, evaluate, prioritize, remediate và validate các security vulnerabilities trong hệ thống, ứng dụng và mạng.

Mục tiêu: Giảm attack surface và risk bằng cách và vulnerabilities trước khi attacker khai thác chúng.

2 Vulnerability Management Lifecycle



3 Khái niệm chính

- Asset:** Bất kỳ device, application, service, cloud resource, user account, v.v.
- Vulnerability:** Điểm yếu có thể bị khai thác.
- CVE (Common Vulnerabilities and Exposures):** ID duy nhất cho một vulnerability đã biết.
- CVSS (Common Vulnerability Scoring System):** Điểm chuẩn (0.0 – 10.0) thể hiện mức độ nghiêm trọng.
- Risk** = Likelihood of exploit × Impact

4 Mức độ nghiêm trọng CVSS (v3.1)

Score	Mức độ	Mô tả	Hành động
9.0 – 10.0	Critical	Risk cao, dễ khai thác, impact lớn	Và ngay lập tức
7.0 – 8.9	High	Risk cao, impact đáng kể	Và càng sớm càng tốt
4.0 – 6.9	Medium	Risk trung bình, impact hạn chế	Và sớm
0.1 – 3.9	Low	Risk thấp, impact tối thiểu	Và khi có thể
0.0	None	Chỉ mang tính thông tin	Theo dõi

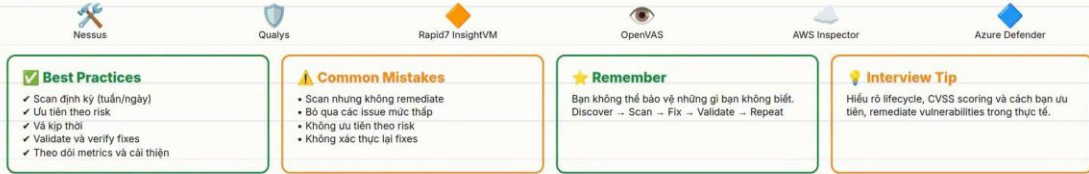
5 Yếu tố ưu tiên Risk

- CVSS Score (Base Score)
 - Exploitability (có exploit chưa?)
 - Asset Criticality (business impact)
 - Exposure (Internet facing hay internal)
 - Data Sensitivity
 - Compensating Controls
 - Threat Intelligence
- Higher Risk = Higher Priority

6 Ví dụ Remediation

- Patch Management**
 - OS Updates
 - Application Patches
 - Firmware Updates
 - Third-party Software Updates
- Configuration Fixes**
 - Tắt các service không cần thiết
 - Đổi mật khẩu mặc định
 - Thực thi mã hóa
 - Áp dụng secure baselines

7 Công cụ sử dụng



14. SECURITY MONITORING & SIEM

14

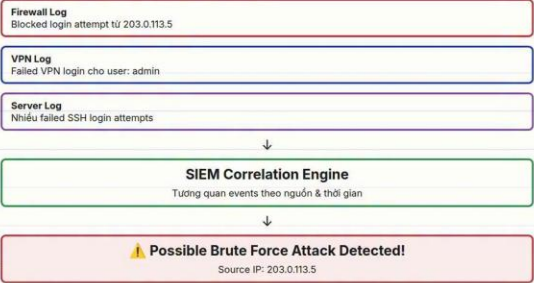
1 Khái niệm chính

- **Logs:** Bản ghi hoạt động được tạo bởi systems, applications, devices và users.
- **Security Events:** Các sự kiện cụ thể có liên quan đến security.
- **Alerts:** Thông báo được tạo khi event khớp với rule hoặc cho thấy hoạt động khả nghi.
- **SIEM:** Thu thập, tương quan và phân tích security events theo thời gian thực.
- **SOC:** Đội ngũ giám sát, điều tra và phản ứng với threats.

2 Luồng Monitoring



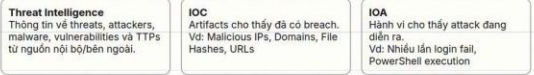
3 Log Correlation (Ví dụ)



4 Detection Rules (Ví dụ)

Nếu xảy ra điều này...	Trigger Alert
5+ failed login attempts từ cùng IP trong 5 phút	Brute Force Alert
User đăng nhập từ vị trí impossible travel	Impossible Travel Alert
Malware phát hiện trên endpoint	Malware Alert
Truyền lượng lớn dữ liệu đến IP bên ngoài	Data Exfiltration Alert
Privileged account dùng ngoài giờ làm việc	Privilege Misuse Alert

5 Threat Intelligence, IOC & IOA



6 Lợi ích của SIEM

- Tầm nhìn tập trung trên toàn environment.
- Phát hiện và cảnh báo threat theo thời gian thực.
- Correlation giúp giảm noise và false positives.
- Hỗ trợ yêu cầu compliance & audit.
- Cải thiện tốc độ incident response.

Best Practices

- ✓ Thu thập logs liên quan từ mọi nguồn
- ✓ Đồng bộ thời gian (NTP)
- ✓ Tune và test detection rules thường xuyên
- ✓ Least privilege cho SIEM access

Common Mistakes

- Thu thập chưa đủ logs
- Alert fatigue
- Không tune/review rule
- Không dùng threat intelligence

Remember

Bạn không thể bảo vệ những gì bạn không thấy.
Monitor → Detect → Respond → Improve

Interview Tip

Hiểu log sources, correlation, IOC vs IOA và cách SIEM hỗ trợ hoạt động SOC.

15. INCIDENT RESPONSE

15

Incident Response là phương pháp có cấu trúc để phát hiện, phản ứng và khôi phục sau các security incidents nhằm giảm thiểu impact và khôi phục hoạt động bình thường.

Incident Response Lifecycle



! Các loại Incident thường gặp

- Malware / Ransomware
- Phishing / BEC
- Unauthorized Access
- Data Breach
- DDoS Attack
- Insider Threat

★ Nguyên tắc chính

- ✓ Hành động nhanh chóng
- ✓ Bảo toàn bằng chứng
- ✓ Giao tiếp rõ ràng
- ✓ Giảm thiểu impact kinh doanh
- ✓ Tuân theo quy trình & playbooks
- ✓ Cải thiện liên tục

🔥 Lưu ý quan trọng

- Speed + Accuracy = Phản ứng hiệu quả
- Chuẩn bị tốt giúp giảm response time
- Dùng bỏ qua documentation
- Mỗi incident là một cơ hội học hỏi

✅ Best Practices

- ✓ Cập nhật IR playbooks
- ✓ Bật logging & monitoring
- ✓ Diễn tập định kỳ
- ✓ Backup & test khôi phục
- ✓ Least privilege access

⚠️ Common Mistakes

- Phát hiện chậm trễ
- Giao tiếp kém
- Không bảo toàn bằng chứng
- Eradication chưa hoàn chỉnh
- Không review sau incident

★ Remember

Chuẩn bị trước, Phát hiện sớm, Phản ứng nhanh, Khôi phục an toàn, Cải thiện liên tục.

💡 Interview Tip

Giải thích từng phase của IR với ví dụ thực tế. Để cấp công cụ như SIEM, EDR, SOAR và Ticketing systems.

16. ETHICAL HACKING & PENETRATION TESTING

16

Ethical Hacking là nỗ lực được ủy quyền nhằm tìm vulnerabilities trong hệ thống, ứng dụng hoặc mạng để giúp tổ chức khắc phục trước khi attacker khai thác.

1 Khái niệm chính

- **Ethical Hacking:** Hacking hợp pháp, có sự cho phép để cải thiện security.
- **Penetration Testing (Pentest):** Mô phỏng tấn công thực tế để kiểm tra security.
- **Mục tiêu:** Identify, exploit (có kiểm soát) và report vulnerabilities để cải thiện phòng thủ.
- **Scope:** Các hệ thống, ứng dụng hoặc mạng được xác định trước.

2 Các loại Pentesting

- **Black Box:** Không có thông tin được cung cấp.
- **Gray Box:** Thông tin một phần.
- **White Box:** Thông tin đầy đủ.
- **External:** Từ bên ngoài tổ chức.
- **Internal:** Từ bên trong mạng.
- Web Application / Mobile / API / Wireless / Cloud / IoT Pentesting

3 Penetration Testing Lifecycle

1. Reconnaissance

Thu thập thông tin về target (OSINT, DNS, WHOIS, mạng xã hội...)

→

2. Scanning

Xác định live hosts, open ports và services đang chạy (Nmap, Masscan)

Ethical Hacking Lifecycle

↓

3. Reporting

Ghi lại findings, impact, bằng chứng và các bước khắc phục rõ ràng.

←

3. Enumeration

Thu thập thông tin chi tiết như users, shares, directories, versions, credentials.

7. Post-Exploitation

Truy cập internal resources, duy trì access, dump creds, pivot.

↑

4. Vulnerability Assessment

Xác định điểm yếu bằng công cụ (Nessus, OpenVAS) và phân tích thủ công.

6. Privilege Escalation

Nâng cao quyền (user → admin/root) trong hệ thống.

←

5. Exploitation

Cố gắng khai thác vulnerabilities để giành access hoặc control.

4 Công cụ phổ biến

- **Recon:** Maltego, theHarvester, Recon-ng
- **Scanning:** Nmap, Masscan
- **Enumeration:** Nessus, SMBEnum, Gobuster
- **Vulnerability Scan:** Nessus, OpenVAS
- **Exploitation:** Metasploit, Burp Suite
- **Password Attacks:** Hydra, John the Ripper
- **Post-Exploitation:** Meterpreter, Mimikatz
- **Reporting:** Dradis, CherryTree

5 Chúng ta tìm gì?

- Cấu hình yếu
- Vulnerabilities chưa vá
- Credentials mặc định/yếu
- Services/ports không an toàn
- Lộ dữ liệu nhạy cảm
- Lỗi business logic

⚠ Luôn xin permission bằng văn bản trước khi test!

6 Tư duy Ethical Hacker

- ✓ Suy nghĩ như attacker, hành động như defender.
- ✓ Tuân theo rules of engagement.
- ✓ Không gây thiệt hại.
- ✓ Bảo vệ quyền riêng tư dữ liệu.
- ✓ Bảo cáo có trách nhiệm.

✓ Best Practices

- ✓ Hiểu rõ scope
- ✓ Dùng công cụ & kỹ thuật mới nhất
- ✓ Validate findings thủ công
- ✓ Giảm thiểu impact hệ thống
- ✓ Cung cấp remediation rõ ràng

⚠ Common Mistakes

- Scan ngoài scope
- Exploit không validate
- Bỏ qua false positives
- Không document đầy đủ

★ Remember

Mục tiêu không phải là hack, mà là bảo vệ.
Find it → Fix it → Protect it.

💡 Interview Tip

Giải thích từng phase kèm công cụ ví dụ và lý do quan trọng. Tập trung vào trách nhiệm pháp lý & đạo đức.

17. DEVSECOPS & SECURE SDLC

17

DevSecOps tích hợp Security vào DevOps và SDLC để bảo mật được xây dựng sẵn, tự động hóa và liên tục xuyên suốt vòng đời phần mềm.

1 Khái niệm chính

- **Secure SDLC:** Security ở mọi giai đoạn của vòng đời phát triển.
- **Shift-Left Security:** Tìm & vá vulnerabilities sớm trong SDLC.
- **DevSecOps:** People + Process + Tools để tự động hóa security.
- **Mục tiêu:** Cung cấp phần mềm an toàn nhanh hơn với feedback liên tục.

2 Secure CI/CD Pipeline



→ Continuous Feedback Loop

3 Công cụ Security trong Pipeline

- **SAST:** Phân tích static code để tìm vulnerabilities sớm trong source code.
- **DAST:** Dynamic testing trên running application để tìm lỗi runtime.
- **SCA:** Software Composition Analysis phát hiện vulnerable open-source components.
- **Secrets Scanning:** Phát hiện hardcoded secrets, API keys, tokens trong code.
- **Dependency Security:** Đảm bảo thư viện bên thứ ba luôn cập nhật & an toàn.
- **Container Scanning:** Scan container images tìm vulnerabilities đã biết.

4 Các giai đoạn Secure SDLC

1. **Requirements** — Yêu cầu security, risk assessment, compliance
2. **Design** — Threat modeling, secure architecture, data flow diagrams
3. **Development** — Secure coding, code reviews, SAST, secrets scanning
4. **Testing** — DAST, SCA, pen testing, vulnerability scanning
5. **Deployment** — Secure configs, IaC scanning, container security
6. **Operations** — Monitoring, patching, incident response, cải thiện liên tục

5 Lợi ích của DevSecOps

- ✓ Phát hiện sớm = chi phí sửa thấp hơn
- ✓ Giảm security risks trong production
- ✓ Security tự động = kết quả nhất quán
- ✓ Release nhanh hơn với security tích hợp sẵn
- ✓ Sẵn sàng compliance & audit tốt hơn
- ✓ Cải thiện hợp tác giữa Dev, Sec & Ops

Remember

Security không phải một giai đoạn, mà là quy trình liên tục. Shift Left = Bảo mật sớm, Bảo mật luôn luôn!

Best Practices

- ✓ Tự động hóa security scans trong CI/CD
- ✓ Dùng Infrastructure as Code (IaC) scanning
- ✓ Cập nhật dependencies & base images
- ✓ Lưu secrets trong vault
- ✓ Least privilege & secure configs

Common Mistakes

- Chỉ thêm security ở cuối
- Bỏ qua kết quả scan thất bại
- Hardcode secrets trong repo
- Dùng thư viện cũ
- Cloud/container cấu hình sai

Interview Tip

Sẵn sàng giải thích: SAST vs DAST vs SCA · Shift Left concept · Security trong CI/CD · Secrets management · Container & dependency security

★ **Key Takeaway:** DevSecOps là xây dựng security vào mọi bước của development và operations.
Secure Code → Secure Build → Secure Deploy → Secure Run

18. ADVANCED CYBERSECURITY + QUICK REVISION

18

1 Zero Trust Model

Never trust, Always verify.

- Verify explicitly
- Least privilege access
- Assume breach
- Micro-segmentation
- Continuous monitoring



2 Threat Modeling

Identify threats sớm trong design.

- Define assets
- Identify threats
- Determine vulnerabilities
- Assess risks
- Plan mitigations
- Validate liên tục



3 Defense in Depth

Dùng nhiều lớp security controls.



Nếu một lớp thất bại, các lớp khác vẫn bảo vệ.

4 Security Architecture

Xây dựng hệ thống an toàn, scalable.

- Secure by Design
- Segmentation
- Mã hóa mọi nơi
- Secure access (IAM)
- Logging & Monitoring
- High Availability



5 Risk Management

Hiểu risk, ra quyết định tốt hơn.

- Xác định assets
- Xác định threats
- Đánh giá likelihood
- Đánh giá impact
- Tính toán risk
- Xử lý & theo dõi risk



6 MITRE ATT&CK Overview

Framework hiểu adversary behavior.

- Tactics: 14 mục tiêu cấp cao
- Techniques: 100+ cách thức
- Dùng cho detection, threat hunting & defense



7 Lộ trình Career Cybersecurity



8 Top Interview Concepts

- CIA Triad
- Least Privilege
- Zero Trust
- OWASP Top 10
- Encryption vs Hashing
- MFA & IAM
- Network Security
- Vulnerability vs Exploit
- CVE, CVSS
- SIEM & SOC
- Incident Response Phases
- MITRE ATT&CK
- SAST vs DAST vs SCA
- Cloud Shared Responsibility

9 Tổng kết chính

- Cybersecurity là liên tục, không phải một lần.
- People, Process và Technology phải phối hợp.
- Prevent -> Detect -> Respond -> Recover -> Improve
- Security là trách nhiệm của mọi người.
- Luôn cập nhật, thực hành labs và xây dựng kỹ năng thực tế.
- Suy nghĩ như attacker, phòng thủ như pro.

Best Practice Summary

Implement Zero Trust

Detect Early

Response Prepared

Recover Quickly

Always Secure, Always Learning